Lab 5: Issue Table (bike_share_stations.py)

Kundhan Vudutha · PES1UG24AM327 · Section F
Assigned repo: SETAPESU26/L5_23_bike_share_stations

Line numbers refer to the original file. Ordered by severity, highest first.

#	Issue	Tool / Code	Type	Line(s)	Description	Fix Approach
1	SQL injection	Bandit B608 (Medium)	Security	9	The INSERT is built by concatenating `name`, `capacity` and `bikes` into the SQL string. A name like `O'Brien Sq` breaks the query, and a crafted name can run arbitrary SQL.	Use a parameterised query with `?` placeholders and pass the values as a tuple.
2	Mutable default argument	Pylint W0102	Bug	8	`log=[]` is created once at definition time, so every call to `addStation` appends to the same list and the returned log keeps growing across unrelated calls.	Default to `None` and create a new list inside the function when `log is None`.
3	Broad exception swallowed	Pylint W0718, Bandit B110 (Low)	Bug / Security	32-35	`except Exception: pass` hides every error in `resetStation`, so a failed reset looks like a success.	Catch only `sqlite3.Error`, report it, and return `False`; return `True` on success.
4	Insecure random for PIN	Bandit B311 (Low)	Security	22	`random.randint` is a predictable PRNG, unsuitable for an unlock PIN that acts as a credential.	Use `secrets.randbelow(9000) + 1000` from the `secrets` module.
5	Crash on missing station	Pylint C0121, Flake8 E711	Bug	39-40	`row[0] == None` uses equality for a singleton, and when the station id does not exist `row` is `None`, so `row[0]` raises `TypeError`.	Check `row is None or row[0] is None` before comparing.
6	Inconsistent return	Pylint R1710	Bug	14-18	`rentBike` returns `True` on success but implicitly returns `None` on failure.	Add an explicit `return False`.
7	Unused variable	Pylint W0612, Flake8 F841	Code smell	27	`summary = len(stations)` is computed and never used.	Remove the line.
8	Non snake_case names	Pylint C0103	Style	8, 14, 21, 25, 31, 38	camelCase function names (`addStation`, `rentBike`, ...) violate PEP 8.	Rename to `add_station`, `rent_bike`, `unlock_pin`, `full_stations`, `reset_station`, `has_bikes`.
9	Missing docstrings	Pylint C0114, C0116	Style	1, 8, 14, 21, 25, 31, 38, 45	No module or function docstrings.	Add a module docstring and a one-line docstring per function.
10	Module-level side effect	(review)	Design	53	`main()` runs on import, so importing the module for testing executes the demo.	Wrap the call in `if __name__ == "__main__":`.
11	Lines too long	Flake8 E501, Pylint C0301	Style	5, 9, 15, 17, 26, 33, 39	Lines exceed 79 chars (Flake8) or 100 chars (Pylint).	Split SQL strings and call arguments across lines.
12	Trailing whitespace	Flake8 W291, Pylint C0303	Style	27	Trailing spaces after `summary = len(stations)`.	Removed together with the unused variable.

Results

Tool	Before	After
Pylint	3.89/10, 22 messages	10.00/10, 0 messages
Bandit	3 issues (1 Medium, 2 Low)	No issues identified
Flake8	10 violations	0 violations

Program output is unchanged apart from the random PIN: `True True` then `<pin> ['Central Park'] True`.